

REVISIÓN DE SEGURIDAD · 19 DE SEPTIEMBRE DE 2026

Qué está bien, qué falta y qué pide una certificación.

Revisión integral hecha con datos reales: políticas y funciones de la base, buckets de fotos, MFA de las cuentas, librerías y cabeceras de la app, secretos en el repositorio y protección de la rama de producción. La base está bien protegida. Lo que falta para certificar no es tanto código como **controles y evidencia**: quién puede qué, cómo se prueba y dónde queda escrito.

inventiapp.cl · contacto@inventiapp.cl

ESTADO

BIEN

Verificado. Sirve como evidencia para un cuestionario de seguridad.

CRÍTICO

Hueco real o requisito básico de cualquier certificación. Primero.

IMPORTANTE

Defensa que falta o control débil. No expone datos hoy, pero un escáner lo marca.

EVIDENCIA

No es técnico: política escrita, prueba hecha o documento del proveedor.

ÁMBITO

SEGURIDAD

Quién ve qué, y qué puede suplantarse o inyectarse.

DATOS

Pérdida, integridad, respaldo y retención de la información.

OPERACIÓN

Rutinas, revisiones y fechas que hay que cumplir.

DOCUMENTACIÓN

Políticas y registros que una auditoría pide ver.

CONTENIDO

01 Lo que ya está bien

pág. 2

03 Qué pide una certificación

pág. 5

02 Hallazgos: críticos e importantes

pág. 3-4

04 Orden propuesto

pág. 6

Si hay que elegir uno solo para esta semana: activar MFA en las tres cuentas de administrador. Cero cuentas la usan hoy, y es lo primero que pregunta cualquier cliente.

Verificado el 19 de septiembre

Cada punto se comprobó contra la base o el repositorio, no contra lo que dice la documentación. Sirven tal cual como respuesta a un cuestionario de seguridad de un cliente.

Aislamiento entre empresas (RLS)

BIEN

Las 40 tablas tienen RLS activo y políticas. Cada empresa ve solo lo suyo; un usuario normal no ve nada ajeno en ninguna. Verificado en agosto con barrido completo y de nuevo hoy.

Vistas y funciones

BIEN

Todas las vistas usan `security_invoker`. Las 17 funciones con privilegios elevados tienen `search_path` fijo y no las puede ejecutar el rol anónimo (salvo un trigger interno conocido). Después de cada migración se revisa el advisor y los parámetros inválidos.

Fotos privadas por empresa

BIEN

El bucket de fotos no es público; solo se sube, lee y actualiza dentro de la carpeta de la propia empresa, con URL firmadas temporales. Límite de 20 MB y solo imágenes.

Sin secretos en el repositorio

BIEN

La clave de servicio y la de Flow viven solo en variables de entorno de Supabase y en secretos de GitHub. En el código público va únicamente la clave anónima, que es pública por diseño. El archivo de respaldo está en `.gitignore`.

Cobros y registro

BIEN

Los avisos de Flow no se creen: la función consulta a Flow con firma HMAC antes de tocar una suscripción. El registro de empresas va por una función con permisos acotados.

Auditoría y trazabilidad

BIEN

Cada cambio en conteos, materiales, movimientos y documentos queda con antes, después, quién y cuándo. Correcciones y anulaciones exigen motivo y no borran nada.

Pruebas antes de publicar

BIEN

Cada PR corre pruebas unitarias, de esquema y de navegador real en CI. Ningún cambio se publica en rojo. Sentry avisa de errores en producción.

Correo y dominio

BIEN

SPF y DKIM configurados; el remitente es `contacto@inventiapp.cl`. DMARC existe, aunque todavía en modo observación (ver hallazgo 10). Una sola sesión activa por cuenta.

Respaldo y recuperación

BIEN

Supabase guarda copias diarias siete días. Existe un script propio de respaldo completo (base, roles, fotos, funciones) y un runbook de recuperación paso a paso. Falta ejecutarlo (ver evidencia).

Infraestructura

BIEN

Postgres 17.6 al día, región São Paulo, cifrado en reposo y en tránsito por Supabase. App servida por GitHub Pages solo por HTTPS. Sentry no recibe datos personales.

Críticos: huecos reales o requisitos básicos

Los tres se resuelven en días, no en semanas. Ninguno expone datos de clientes hoy, pero los tres son lo primero que revisa un auditor.

1 Ninguna cuenta usa MFA, incluidos los tres administradores

CRÍTICO

SEGURIDAD

La app ya permite activar el segundo factor, pero cero cuentas lo tienen. Una contraseña filtrada de un admin da acceso a todo el maestro y los conteos de su empresa. Propuesta: activar MFA en las tres cuentas admin esta semana y, en la app, hacerla obligatoria para el rol admin (aviso al entrar, bloqueo tras un plazo).

Quién: Joel, Victoria y Claudio hoy; desarrollo para hacerla obligatoria

Esfuerzo: 5 minutos por cuenta; media sesión para obligarla

2 La rama de producción no está protegida

CRÍTICO

OPERACIÓN

Cualquiera con acceso al repositorio puede subir directo a `main`, sin PR ni pruebas, y GitHub Pages lo publica al instante. Hay además 42 ramas viejas sin borrar. Propuesta: exigir PR con CI en verde para `main`, sin subida directa, y borrar las ramas ya fusionadas.

Quién: Joel, en la configuración del repositorio Esfuerzo: 10 minutos

3 La librería de Excel tiene vulnerabilidades conocidas

CRÍTICO

SEGURIDAD

La app carga `xlsx` 0.18.5 desde un CDN. Tiene dos CVE publicados (2023-30533 y 2024-22363, corregidos en 0.19.3 y 0.20.2, que el autor ya no publica en npm). Solo la usan administradores con sus propios archivos, así que el riesgo real es bajo, pero cualquier escáner la marca. Propuesta: servirla desde el repositorio en la versión corregida, como ya se hace con `pdf-lib`.

Quién: desarrollo Esfuerzo: una sesión, con pruebas de carga de Excel

Importantes: defensas que faltan

4 Sin Content Security Policy ni integridad en los scripts externos

IMPORTANTE

SEGURIDAD

La app carga tres scripts desde CDN (lector de códigos, Excel y Sentry) sin hash de integridad. Si alguien compromete el CDN, ejecuta código dentro de tu app con la sesión del usuario. GitHub Pages no permite cabeceras, pero sí una etiqueta CSP en el HTML y SRI con versiones fijas.

Quién: desarrollo Esfuerzo: media sesión

5 Políticas declaradas para "public" y permisos de tabla al rol anónimo

IMPORTANTE

SEGURIDAD

34 políticas RLS aplican a cualquier rol y el rol anónimo tiene permisos sobre 30 tablas. Hoy no filtra nada porque las funciones de empresa devuelven vacío sin sesión, pero es defensa por accidente. Propuesta: políticas solo para `authenticated` y revocar al anónimo todo salvo lo que necesita (dejar un lead desde la landing).

Quién: desarrollo Esfuerzo: una sesión, con barrido de verificación como usuario anónimo

6 Sesiones que no caducan

IMPORTANTE

SEGURIDAD

385 sesiones vivas para 11 usuarios; la más antigua es del 12 de agosto. Un iPad perdido sigue entrando indefinidamente. Propuesta: tope de duración y cierre por inactividad en Supabase Auth (plan Pro), más "cerrar las otras sesiones" en Configuración.

Quién: Joel en Supabase; desarrollo para el botón Esfuerzo: chico

7 Política de contraseñas dispareja

IMPORTANTE

SEGURIDAD

Los formularios de creación exigen 10 caracteres; el de inicio de sesión acepta 6. Falta fijar el mínimo del lado de Supabase (que es el que manda) y activar la protección contra contraseñas filtradas.

Quién: Joel en Supabase Auth; desarrollo para el formulario Esfuerzo: 15 minutos

8 Auditoría con retención de 14 días y visible entre empresas para el súper admin

IMPORTANTE

DATOS

El registro de auditoría se purga a los 14 días; una certificación pide entre 90 días y un año. Y el súper admin lee la auditoría de todos los clientes: es deliberado, pero hay que poder explicarlo por escrito, o cerrarlo. Propuesta: retención de 180 días y una frase en la política de acceso.

Quién: desarrollo (una migración) y Joel (la decisión) Esfuerzo: chico

9 Registro de empresas sin CAPTCHA ni límite de intentos

IMPORTANTE

SEGURIDAD

La función pública que crea empresas de prueba no tiene freno contra scripts. Ya está en la lista de pendientes. Propuesta: Turnstile de Cloudflare (gratis) y un límite por IP y por hora.

Quién: desarrollo Esfuerzo: una sesión

10 Cabos menores

IMPORTANTE

OPERACIÓN

DMARC sigue en `p=none` (pasar a cuarentena en octubre, como estaba planeado). Un usuario activo no entra hace más de 90 días. La extensión `pg_net` vive en el esquema público. Dependabot no está activado, así que nadie avisa cuando una librería tiene un CVE nuevo.

Quién: Joel Esfuerzo: 30 minutos en total

Evidencia, más que código

Para vender a una minera suele bastar un **cuestionario de seguridad** más un **pentest externo**. Una certificación formal (ISO 27001 o SOC 2) pide lo mismo y, además, que todo esté escrito, vigente y con responsable. Esto es lo que hoy no existe o no está probado.

A Políticas escritas

EVIDENCIA

DOCUMENTACIÓN

Seguridad de la información, control de acceso (roles, altas y bajas, súper admin), gestión de cambios (lo que ya se hace con PR y CI, escrito), respuesta a incidentes, respaldo y recuperación, retención de datos. Una o dos páginas cada una, en el estilo de los manuales actuales.

B Respaldo ejecutado y restauración probada

EVIDENCIA

DATOS

El script y el runbook existen, pero nunca se corrieron. Correr el respaldo, guardarlo fuera del computador y hacer una restauración de prueba en un proyecto aparte. Con fecha y resultado anotados: eso es lo que pide un auditor.

C Revisión de accesos periódica

EVIDENCIA

OPERACIÓN

Cada tres meses: quién tiene cuenta, con qué rol, último ingreso, y desactivar lo que no se usa. La app ya muestra todo eso en Mi equipo; falta hacerlo rutina y dejar constancia.

D Gestión de vulnerabilidades

EVIDENCIA

SEGURIDAD

Dependabot activo en el repositorio, el advisor de Supabase revisado tras cada migración (ya se hace) y un pentest externo anual con su informe y el cierre de hallazgos.

E Proveedores y contratos

EVIDENCIA

DOCUMENTACIÓN

Guardar los informes SOC 2 de Supabase, GitHub, Cloudflare y Brevo, y tener un acuerdo de tratamiento de datos para firmar con cada cliente: qué datos se guardan, dónde (São Paulo), quién accede y cuánto tiempo.

F Privacidad: Ley 21.719

EVIDENCIA

DOCUMENTACIÓN

La nueva ley chilena de protección de datos entra en vigencia en diciembre de 2026 y aplica a los datos de las personas que usan la app (nombre, correo, quién contó qué). Hace falta una política de privacidad publicada y un procedimiento para eliminar los datos de un usuario que lo pida.

G Incidentes y canal de reporte

EVIDENCIA

OPERACIÓN

Un registro de incidentes (aunque esté vacío), con qué pasó, cuándo se detectó y qué se hizo. Y un `security.txt` en el sitio para que alguien que encuentre un problema sepa a quién escribir.

Tres etapas

La primera cierra huecos reales con poco esfuerzo. La segunda deja la app lista para responder bien un cuestionario de seguridad. La tercera es la certificación formal, que conviene empezar cuando haya un cliente que la exija.

1 Esta semana: lo que cierra huecos y cuesta poco

SEGURIDAD

MFA en las tres cuentas admin (1). Proteger `main` y borrar ramas viejas (2). Mínimo de contraseña y protección contra filtradas en Supabase (7). Caducidad de sesión (6). Dependabot y los cabos menores (10). Todo lo hace Joel en configuraciones, salvo obligar la MFA en la app.

Esfuerzo: una tarde de Joel, media sesión de desarrollo

2 Próximas dos semanas: lista para un cuestionario

DATOS

SRI y CSP (4). Políticas RLS solo para usuarios autenticados (5). `xlsx` en versión corregida y servido desde el repositorio (3). Retención de auditoría a 180 días (8). CAPTCHA en el registro (9). Correr el respaldo y probar la restauración (B). Escribir las políticas cortas (A) y la de privacidad (F).

Esfuerzo: cuatro sesiones de desarrollo, dos tardes de Joel para las políticas

3 Cuando un cliente lo exija: certificación formal

DOCUMENTACIÓN

Pentest externo (D), informes de proveedores y acuerdo de tratamiento de datos (E), revisión de accesos como rutina con constancia (C), registro de incidentes y `security.txt` (G). Con eso se puede entrar a SOC 2 tipo 1 o a ISO 27001 con un consultor; el tiempo típico para una empresa de este tamaño es de tres a seis meses.

Esfuerzo: el pentest y el consultor tienen costo; el resto es rutina

Lo que hoy ya se puede afirmar a un cliente, con evidencia: aislamiento por empresa en todas las tablas, fotos privadas, cifrado en reposo y en tránsito, auditoría de cambios, pruebas automáticas antes de cada publicación y respaldo diario. Lo que todavía no: MFA obligatoria, políticas escritas y una restauración probada.